

# Atividade de Segurança Proativa (ASP)

A Atividade de Segurança Proativa (ASP) é um **score de priorização** que busca maximizar a vantagem de mitigação ao combinar **Risco** e **Esforço de Mitigação** no ciclo de desenvolvimento.

Um projeto que adota a métrica ASP realiza modelagem de ameaças na reunião de planejamento, antecipando identificação de riscos no início do SDLC (**shift-left**).

O cálculo é uma avaliação entre Risco e Esforço de mitigação e pode ser entendido da seguinte forma:

Fórmula de cálculo de Atividade de Segurança Proativa:

$$ASP = R * EM$$

| Fator                            | Significado                                                             | Objetivo                                |
|----------------------------------|-------------------------------------------------------------------------|-----------------------------------------|
| <b>Risco (R)</b>                 | Impacto da vulnerabilidade ou ameaça no negócio.                        | Indicar a gravidade do problema.        |
| <b>Esforço de Mitigação (EM)</b> | Quantidade de trabalho e recursos necessários para corrigir o problema. | Mostrar o custo de resolver o problema. |

Tabela de cálculo de risco:

| Risco (R) | Valor |
|-----------|-------|
| Crítico   | 10    |
| Alto      | 8     |
| Médio     | 3     |
| Baixo     | 1     |

Tabela de cálculo de esforço de mitigação:

| Esforço de Mitigação (EM) | Valor |
|---------------------------|-------|
| Muito Alto (mais difícil) | 3     |
| Alto                      | 5     |
| Médio                     | 8     |

| Esforço de Mitigação (EM) | Valor |
|---------------------------|-------|
| Baixo (mais fácil)        | 10    |

Observação: a escala foi definida de forma que **valores maiores** de EM e R representem **mitigações mais vantajosas** quando multiplicadas, priorizando ameaças de alto impacto e **baixa dificuldade** de correção.

### Interpretação do resultado:

**ASP > 64** → Correção muito vantajosa, pois é uma ameaça de alto risco e de fácil mitigação.

**ASP < 64** → Correção menos vantajosa, pois pode ser um problema de risco baixo ou muito difícil de corrigir.

Relacionando com priorização por valor: no SAFe(**Scaled Agile Framework**), o **WSJF (Weighted Shortest Job First)** prioriza maximizando o **Cost of Delay (CoD)** — que inclui valor para o negócio e usuário, urgência temporal e redução de riscos ou habilitação de oportunidades — dividido pelo **Job Size**. O **ASP não é WSJF**, mas dialoga com esse princípio ao tornar explícita a combinação de **Risco** e **Esforço de Mitigação** para priorização de segurança. Quando fizer sentido, pode-se estimar um **CoD de riscos de segurança** para complementar a decisão de produto.

### Exemplo prático:

| Ameaça                 | R (Risco)    | EM (Esforço)           | ASP = R × EM |
|------------------------|--------------|------------------------|--------------|
| SQL Injection          | 10 (Crítico) | 10 (Baixo esforço)     | <b>100</b>   |
| XSS Persistente        | 8 (Alto)     | 8 (Médio esforço)      | <b>64</b>    |
| Privilege Escalation   | 10 (Crítico) | 3 (Muito alto esforço) | <b>30</b>    |
| Information Disclosure | 3 (Médio)    | 10 (Baixo esforço)     | <b>30</b>    |

### Prioridade no ciclo:

- SQL Injection (ASP 100) → alto impacto, fácil de corrigir.
- XSS Persistente (ASP 64) → alto impacto, esforço moderado.
- Privilege Escalation e Information Disclosure empatam (ASP 30).